

Secure Coding Practices

What Is The CIA Triad?

The CIA triad is an important concept in cybersecurity, and is used to help determine what it means for something to be secure. Its three components are:

- Confidentiality: Assets should not be accessible without authorization.
- Integrity: Assets should not change state unexpectedly.
- Availability: Assets should be available to those authorized to access them.

An asset can be anything from a piece of data to a computer to a whole network.

What Is Injection?

Injection flaws are vulnerabilities because they allow attackers to send malicious data to an interpreter as part of a command or query.

What Is XSS?

Cross-Site Scripting (XSS) is a vulnerability because it allows attackers to inject malicious scripts into content that is served to other users.

What Is Broken Authentication?

Broken Authentication is a category of vulnerability where the methods and systems used to verify user identity are insufficient or can be bypassed. Broken Authentication is not specific to any one programming language, and is dangerous due to the potential for attackers to assume user's identities.

What Is Sensitive Data Exposure?

Sensitive Data Exposure is a category of vulnerability where sensitive data is not adequately protected or otherwise needlessly vulnerable.

What Is XXE?

XML External Entities Injection (XXE) is a vulnerability because it allows attackers to exploit poorly configured XML.

What Is Broken Access Control?

Broken Access Control is a vulnerability because it allows attackers to bypass authorization checks and perform actions they should not be permitted to do.

What Is Security Misconfiguration?

Security Misconfiguration is a class of vulnerability where security is impeded due to how one or more pieces of software are configured.

What Is CSRF?

Cross-site request Forgery (CSRF) is a vulnerability in which an attacker can trick a victim into sending a malicious request from the victim's browser. These requests are sent without the victim's knowledge or consent and exploit web applications' trust for the user's browser or session.

Memory Mismanagement Part 1

Use After Free, Double Free, and Memory Leaks are all bugs that can arise from improper memory management.

- Use After Free occurs when a program attempts to use memory that has already been freed.
- Double Free occurs when a program attempts to free the same memory block twice.
- Memory Leaks occur when a program fails to free memory when it is no longer needed, increasing memory usage over time.

In addition to negatively impacting program stability, clever hackers can potentially exploit the undefined behavior these bugs create.

Memory Mismanagement Part 2: Buffers

Buffer Overflow and Buffer Overread are vulnerabilities that involve writing or reading data to or from a buffer of insufficient size. Buffer overflow can result in arbitrary code execution, while buffer overread can expose sensitive data.

What Is Insecure Deserialization?

Insecure Deserialization is a vulnerability because it allows attackers to manipulate serialized objects to pass harmful data into the application logic, which can result in remote code execution, replay attacks, injection attacks, or privilege escalation.

What Is Using Components With Known Vulnerabilities?

Using Components with Known Vulnerabilities are vulnerable because attackers can exploit these known issues to compromise the application or the underlying system.

What Is Insufficient Logging And Monitoring?

Insufficient Logging and Monitoring is a vulnerability because it fails to detect security breaches in a timely manner or to provide information necessary for forensic analysis.

What Is Security Misconfiguration?

Security Misconfiguration is a vulnerability because it results from insecure configuration settings in the application, application server, web server, database server, platform, or any component the application relies on.

